

KI-gestützte OSINT-Ermittlungsplattform

Ein eigener Verbindungsserver zu unseren Ermittlungsquellen —
mit lückenloser Nachvollziehbarkeit und automatischer
Beziehungsdarstellung.

Dokument	Konzept- und Entscheidungsgrundlage für die Ermittlungsgruppe
Zielgruppe	Ermittelnde, Gruppenleitung, Datenschutz, Staatsanwaltschaft
Version	1.0 — Entwurf zur internen Besprechung
Stand	13. August 2026
Klassifizierung	<vor Verteilung festlegen>

Zum Charakter dieses Dokuments. Alle Angaben zu Preisen, Nutzungsgrenzen und Lizenzbedingungen wurden am 11. August 2026 aus den Herstellerunterlagen erhoben und sind im Text mit dem jeweiligen Stand gekennzeichnet. Solche Angaben veralten schnell und sind vor einer Beschaffung erneut zu prüfen. Punkte, die noch offen sind, sind als solche benannt und nicht überspielt — insbesondere in **Kapitel 11** (S. 17) und **Kapitel 13** (S. 20).

33

Quellen

26

davon ohne Zusatzkosten

~5.—

laufend pro Monat

13

Wochen bis Abnahme

Erstellt als Diskussionsgrundlage. Kein Beschaffungsantrag, keine Freigabe.
Die in **Kapitel 13** (S. 20) aufgeführten Entscheide sind vor Baubeginn zu treffen.

— Inhalt

1	Das Wichtigste in Kürze	3
	Worum es geht, was es kostet, was zu entscheiden ist	
2	Ausgangslage — wie wir heute arbeiten	4
	Wo der heutige Ablauf uns Zeit und Belege kostet	
3	Was wir bauen	5
	Das Konzept in sechs Schritten	
4	Aufbau des Systems	6
	Drei Ebenen, streng getrennt	
5	Die zwei Protokollspuren	8
	Ergebnis und Weg dorthin — beide vollständig	
6	Szenario 1 — Phishing gegen ein KMU	
	Vollständiger Ablauf, drei Runden	
7	Szenario 2 — Ransomware und Kryptospur	
	Anderer Werkzeugmix, gleiches Verfahren	
8	Welche Quellen angebunden werden	10
	Rund 33 Quellen, nach Phase gruppiert	
9	Datenfluss und Vertrauensgrenzen	11
	Was das Haus verlässt — und was nicht	
10	Modul Gesichtserkennung	16
	Rechtsrahmen, Galerienmodell, Fachlogik	
11	Absicherung und Gerichtsfestigkeit	17
	Was uns im Verfahren trägt	
12	Kosten	19
	Einmalig, laufend und offen	
13	Zeitplan und offene Entscheide	20
	Was wir von euch brauchen	
A	Anhang — Werkzeugverzeichnis	22
	Alle 39 Werkzeuge mit Kosten und Status	

— Wer liest was

Das Dokument ist für mehrere Zielgruppen geschrieben. Wer wenig Zeit hat, liest die hier genannten Kapitel. Zusätzlich steht zuoberst in jedem Kapitel eine **Kernaussage** im dunklen Feld — wer nur diese elf Zeilen liest, kennt den Kern des Vorhabens.

Rolle	Empfohlene Kapitel	Weshalb
Ermittelnde	1 · 3 · 6 · 7	Was sich am Arbeitsalltag ändert, wie ein Fall konkret abläuft, welche Quellen zur Verfügung stehen
Gruppenleitung	1 · 12 · 13	Nutzen, Kosten, Zeitbedarf und die acht Entscheide, die vor Baubeginn zu treffen sind
Datenschutz	5 · 9 · 10 · 11	Protokollspuren, Datenflüsse und Vertrauensgrenzen, biometrische Verarbeitung
Staatsanwaltschaft	5 · 10 · 11	Nachvollziehbarkeit beider Spuren, Rechtsrahmen der Gesichtserkennung
Technik / Betrieb	4 · 5 · 8 · 11	Aufbau, Schnittstellen, Betriebsanforderungen

Ein Satz zur Einordnung

Wir ersetzen weder Maltego noch die Ermittlerin oder den Ermittler. Wir automatisieren das Zusammentragen und Verknüpfen von Informationen aus Quellen, die wir ohnehin nutzen — und wir protokollieren dabei lückenlos, was wann von wem abgefragt wurde. Die Bewertung bleibt vollständig bei uns.

1 Das Wichtigste in Kürze

KERNAUSSAGE

Ein eigener Verbindungsserver zu unseren Quellen. 33 Quellen, davon 26 ohne Zusatzkosten, rund 5 Franken laufend pro Monat — und drei Entscheide, die vor Baubeginn zu treffen sind.

Wir bauen einen eigenen Verbindungsserver, über den ein Sprachmodell auf unsere bestehenden Ermittlungsquellen zugreifen kann. Die Ermittlerin beschreibt in Klartext, was sie wissen will. Das System fragt die passenden Quellen ab, führt die Ergebnisse in einem gemeinsamen Datenbestand zusammen und erzeugt daraus eine Beziehungsdarstellung sowie einen Berichtsentwurf. Jeder einzelne Datenpunkt bleibt dabei auf seine Quelle zurückführbar.

33

angebundene Quellen
in der Zielausbaustufe

26

davon kostenlos
oder bereits lizenziert

~5.—

wiederkehrende Kosten
pro Monat

13

Wochen bis zur
Abnahmefähigkeit

Was sich für die Ermittelnden ändert

- **Kein Abtippen zwischen Werkzeugen mehr.** Heute kopieren wir IP-Adressen, Domains und Hashwerte von Hand zwischen einem guten Dutzend Oberflächen. Das entfällt.

- **Ein gemeinsames Lagebild statt zwölf Browser-Tabs.** Alle Treffer landen im selben Datenbestand und lassen sich als zusammenhängender Graph betrachten.
- **Ein durchgehendes Protokoll.** Heute ist nur schwer zu rekonstruieren, wer wann welche Quelle abgefragt hat. Künftig liegt das lückenlos und manipulationssicher vor.
- **Der eigene Bestand wird mitgedacht.** Treffer aus unserem MISP erscheinen gleichberechtigt neben externen Quellen — heute geht dieser Abgleich oft schlicht vergessen.

Was sich bewusst nicht ändert

- **Maltego bleibt.** Für die manuelle Analyse am Graphen bleibt Maltego Desktop unser Werkzeug. Das neue System steht daneben, nicht darüber.
- **Die Bewertung bleibt bei uns.** Das System trägt zusammen und stellt dar. Es zieht keine Schlüsse, die nicht als solche gekennzeichnet sind.
- **Keine Abfrage ohne Freigabe.** Vor jeder kostenpflichtigen oder nach aussen sichtbaren Abfrage steht eine Vorschau, die bestätigt werden muss.

Drei Entscheide, die vor dem Baubeginn zu treffen sind

Erstens: Betreiben wir das Sprachmodell selbst oder in der Cloud? Davon hängt ab, ob Falldaten unser Haus verlassen. Alles andere in diesem Konzept bleibt intern.

Zweitens: Für VirusTotal brauchen wir eine kostenpflichtige Vereinbarung — die kostenlose Schnittstelle ist für unseren Einsatzzweck vertraglich nicht zulässig (Kapitel 6).

Drittens: Für die Gesichtserkennung ist die Modell-Lizenz zu klären, bevor das Modul gebaut wird (Kapitel 8).

2 Ausgangslage — wie wir heute arbeiten

KERNAUSSAGE

Der heutige Ablauf ist nicht falsch, aber langsam und schlecht dokumentiert. Am schwersten wiegt die fehlende Herkunftsdocumentation.

Der heutige Ablauf ist nicht falsch. Er ist nur langsam, schlecht dokumentiert und fehleranfällig an genau den Stellen, an denen es später im Verfahren darauf ankommt.

Der typische Ablauf heute

Eine Ermittlerin erhält eine verdächtige Domain. Sie öffnet nacheinander Shodan, urlscan, crt.sh, VirusTotal, AbuseIPDB und DomainTools. Aus jedem Werkzeug kopiert sie von Hand Ergebnisse heraus, fügt sie in Maltego oder eine Notiz ein und pivotiert weiter. Für jeden gefundenen Indikator beginnt derselbe Kreislauf von vorn.

Wo das konkret weh tut

Problem	Auswirkung heute	Künftig
Manuelles Übertragen	Zeitaufwand, Tippfehler, übersehene Indikatoren bei grossen Ergebnismengen	Übertragung erfolgt maschinell und vollständig
Kein durchgehendes Protokoll	Wer hat wann welche Quelle abgefragt? Nur mühsam rekonstruierbar	Lückenlose, verkettete Protokollierung je Fall und Person

Herkunft geht verloren	Im Graphen steht eine IP — woher sie stammt, weiss oft nur die Person, die sie eingetragen hat	Jeder Knoten trägt Werkzeug, Abfrage und Zeitstempel
Eigener Bestand wird übersehen	Der Abgleich mit MISP passiert unsystematisch oder gar nicht	Der eigene Bestand wird bei jedem Indikator automatisch mitgeprüft
Kontingente unkontrolliert	Abfragekontingente kostenpflichtiger Dienste sind unbemerkt aufgebraucht	Verbrauch je Fall sichtbar und begrenzbare
Ungewollte Signalwirkung	Öffentliche Scans können die Zielperson warnen — heute nicht systematisch gesteuert	Nicht-öffentlich als Grundeinstellung, Vorschau vor jeder Abfrage nach aussen

Der Punkt, der uns im Verfahren am ehesten trifft

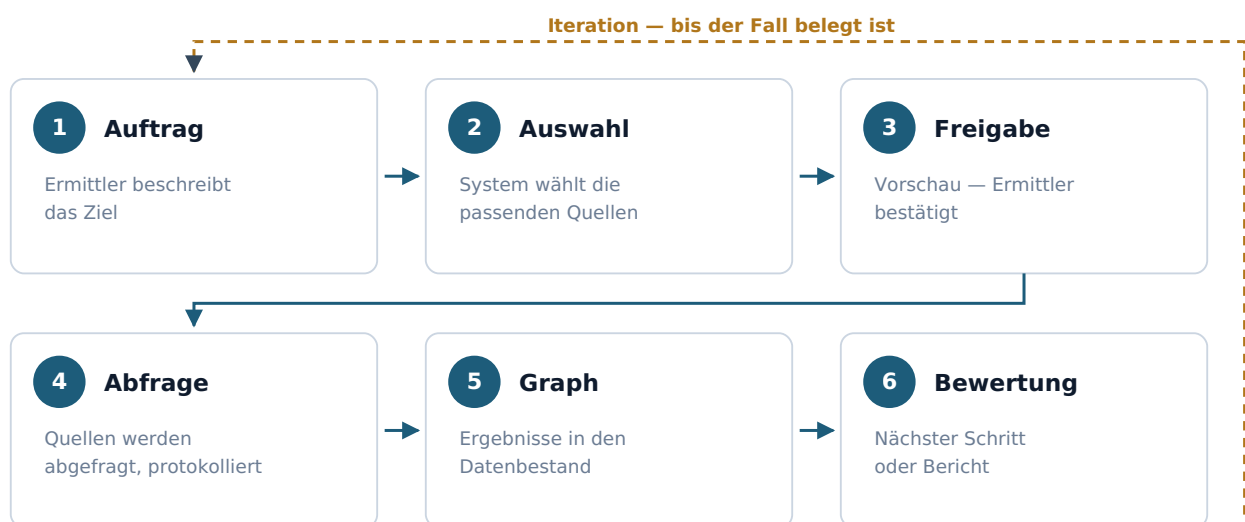
Von allen aufgeführten Punkten ist die fehlende Herkunftsdocumentation der kritischste. Wenn im Bericht steht, eine Adresse gehöre zu einem bestimmten Server, muss ein Jahr später belegbar sein, aus welcher Quelle diese Aussage stammt, wann sie erhoben wurde und wer sie erhoben hat. Genau das leistet unser heutiges Vorgehen nur unvollständig — und genau dort setzt der Aufbau in **Kapitel 4** (S. 6) an.

3 Was wir bauen

KERNAUSSAGE

Sechs Schritte, in denen das System vorschlägt und der Mensch auslöst. Keine Abfrage nach aussen ohne bestätigte Vorschau.

Ein Sprachmodell erhält über eine definierte Schnittstelle Zugriff auf unsere Ermittlungsquellen. Es darf diese Quellen nicht frei abfragen, sondern nur über Werkzeuge, die wir bereitstellen, unter Regeln, die wir setzen, und mit Protokollierung, die es nicht umgehen kann.



Der Ermittlungskreislauf. Entscheidend ist Schritt 3: keine Abfrage nach aussen ohne bestätigte Vorschau.

Die sechs Schritte im Einzelnen

1 Auftrag in Klartext

Die Ermittlerin schreibt beispielsweise: «Diese Domain ist in einem Phishing-Fall aufgetaucht. Zeig mir die zugehörige Infrastruktur, prüfe unseren eigenen Bestand und schau, ob etwas davon sanktioniert ist.» Kein Kommandozeilenwissen nötig.

2 Auswahl der Quellen

Das System schlägt vor, welche Quellen dafür sinnvoll sind, und in welcher Reihenfolge. Es wählt aus dem, was angebunden und für diesen Fall freigegeben ist.

3 Vorschau und Freigabe

Vor der Ausführung zeigt das System exakt an, welche Abfragen es senden würde, an welche Dienste, und wie viel Kontingent das verbraucht. Erst nach Bestätigung läuft etwas. Diese Sperre lässt sich nicht abschalten.

4 Ausführung und Protokollierung

Die Abfragen laufen. Jede einzelne wird protokolliert: Zeitpunkt, Fall, Person, Werkzeug, Abfrageinhalt, Ergebnisumfang. Zugangsschlüssel liegen ausschliesslich auf dem Server — weder das Sprachmodell noch die Ermittelnden sehen sie.

5 Zusammenführung

Die Ergebnisse werden in ein einheitliches Format überführt und in den gemeinsamen Datenbestand geschrieben — mit Herkunftsnachweis an jedem Datenpunkt.

6 Bewertung und nächster Schritt

Das System stellt dar, was neu hinzugekommen ist, und schlägt sinnvolle Anschlussabfragen vor. Die Ermittlerin entscheidet, ob weitergesucht oder der Bericht erstellt wird.

Warum die Freigabe in Schritt 3 nicht verhandelbar ist

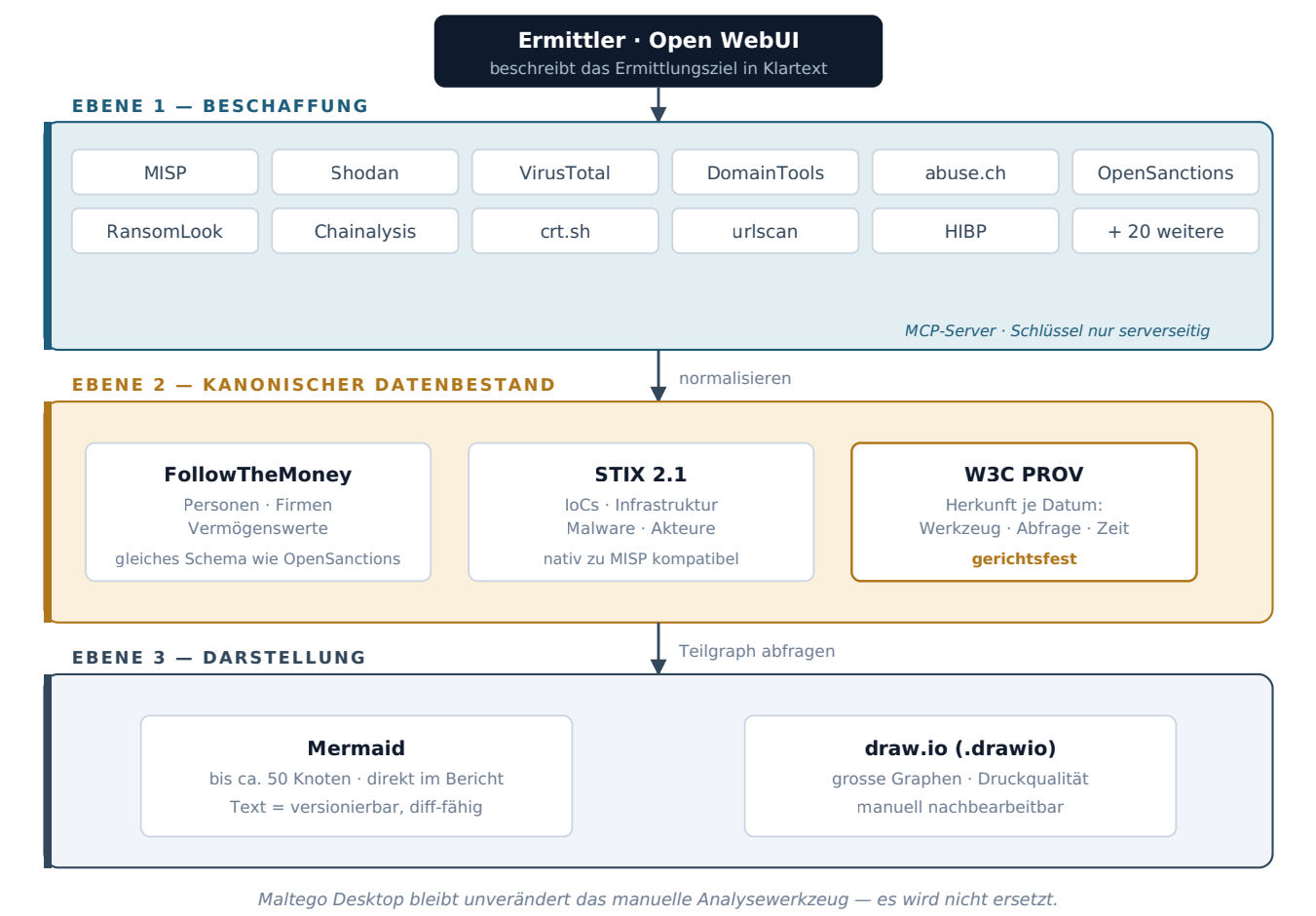
Abfragen kosten Kontingent, und manche sind für die Gegenseite sichtbar. Eine WHOIS- oder Scan-Abfrage gegen die Infrastruktur einer Zielperson kann bemerkt werden. Ein System, das selbstständig Dutzende Abfragen auslöst, kann eine verdeckte Ermittlung auffliegen lassen. Deshalb gilt: Vorschlagen darf das System, auslösen nur der Mensch.

4 Aufbau des Systems

KERNAUSSAGE

Drei getrennte Ebenen. Die mittlere — der gemeinsame Datenbestand mit Herkunftsnachweis — ist der eigentliche Kern.

Drei Ebenen, streng getrennt. Diese Trennung ist kein technischer Selbstzweck — sie ist der Grund, weshalb das Ergebnis später überprüfbar ist.



Aufbau in drei Ebenen. Die mittlere Ebene ist der eigentliche Kern des Konzepts.

Weshalb die mittlere Ebene entscheidend ist

Man könnte die Ergebnisse der Quellen direkt zeichnen lassen. Das wäre schneller gebaut und im Ergebnis wertlos: Jede Quelle liefert ein anderes Format, Verknüpfungen über Quellen hinweg wären nicht möglich, und die Herkunft ginge beim Zeichnen verloren.

Stattdessen wird jedes Ergebnis in ein einheitliches Modell überführt. Wir stützen uns dabei auf drei etablierte Standards statt auf eine Eigenentwicklung:

Standard	Wofür	Weshalb dieser
FollowTheMoney	Personen, Firmen, Vermögenswerte, Beziehungen	Wird von OpenSanctions und von Rechercheverbünden verwendet. Unsere Sanktionsprüfung spricht damit dieselbe Sprache wie unser Datenbestand.
STIX 2.1	Indikatoren, Infrastruktur, Schadsoftware, Akteure	Ist der native Standard von MISP. Unser bestehender Bestand passt damit ohne Umweg hinein.
W3C PROV	Herkunft jedes einzelnen Datenpunkts	Etablierter Standard für Herkunftsnachweise. Das ist der Teil, der im Verfahren zählt.

Darstellung: zwei Wege, bewusst getrennt

Mermaid beschreibt einen Graphen als Text. Das klingt unspektakulär, hat aber zwei praktische Vorzüge: Die Darstellung ist versionierbar wie ein Dokument, und Unterschiede zwischen zwei Ermittlungsständen lassen sich zeilenweise vergleichen. Mermaid wird allerdings ab etwa 50 Knoten unübersichtlich — deshalb erzeugt das System bewusst kleine, gefilterte Ausschnitte statt eines Gesamtbildes.

draw.io nutzen wir für grosse Graphen und für Druckqualität. Der Vorteil: Die erzeugte Datei lässt sich anschliessend von Hand weiterbearbeiten — für die Aufbereitung einer Einvernahme oder einer Anklageschrift ist das entscheidend. draw.io kann Mermaid direkt einlesen, die beiden Wege sind also durchgängig.

Zum Verhältnis zu Maltego

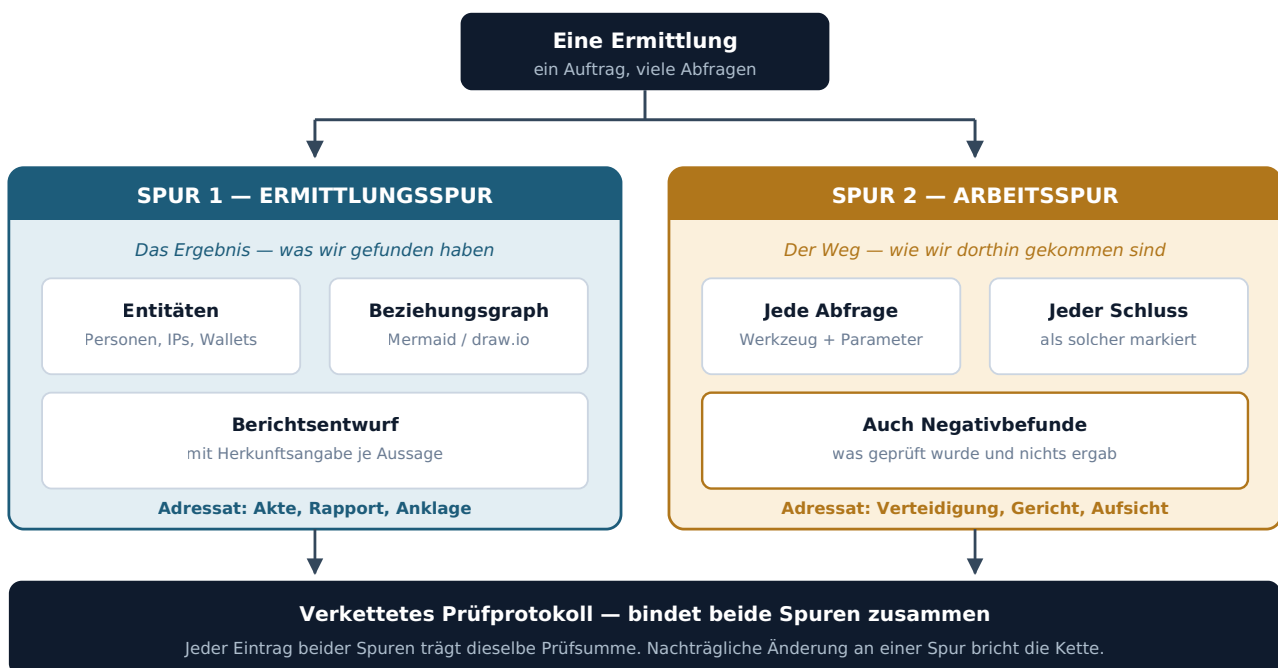
Wir haben geprüft, ob sich Maltego Desktop von aussen fernsteuern lässt, um die dort lizenzierten kommerziellen Transforms automatisiert zu nutzen. Das Ergebnis: Es gibt dafür keinen dokumentierten und unterstützten Weg, der ohne Umgehung von Lizenzmechanismen auskäme. Wir verzichten darauf bewusst und greifen stattdessen direkt auf die Schnittstellen der Anbieter zu — dort, wo wir ohnehin Verträge haben. Maltego bleibt unverändert unser Werkzeug für die manuelle Analyse.

5 Die zwei Protokollspuren

KERNAUSSAGE

Das System liefert zwei gleichwertige Produkte: das Ermittlungsergebnis und den lückenlosen Nachweis, wie es zustande kam. Auch Negativbefunde und Schlussfolgerungen des Modells stehen im Protokoll.

Ein Ergebnis ohne nachvollziehbaren Weg ist im Verfahren wenig wert. Deshalb erzeugt jede Ermittlung zwei getrennte, vollständige Spuren — die eine für die Akte, die andere für die Überprüfung.



Zwei Spuren aus einer Ermittlung. Beide sind über dieselbe Prüfkette gegen nachträgliche Änderung gesichert.

Spur 1 — die Ermittlungsspur

Das, was wir gefunden haben: Entitäten, Beziehungen, der Graph, der Berichtsentwurf. Diese Spur beantwortet die Frage *was wissen wir jetzt*. Sie geht in die Akte, in den Rapport und gegebenenfalls in die Anklageschrift.

Spur 2 — die Arbeitsspur

Das, wie wir dorthin gekommen sind: jede einzelne Abfrage mit Werkzeug und Parametern, jedes Ergebnis, jede Schlussfolgerung, jede Freigabe. Diese Spur beantwortet die Frage *wie sind wir darauf gekommen*. Sie ist für die Verteidigung, das Gericht und die Aufsicht bestimmt — und für uns selbst, wenn ein Verfahren ein Jahr später wieder aufgenommen wird.

ARBEITSPROTOKOLL — AUSZUG · FALL KRIPO-2026-0417			Prüfsumme
08:14:02	FALL	eröffnet KRIPO-2026-0417 · Ermittler M.B. · Art. 309 StPO	
08:15:31	AUFTRAG	«Infrastruktur hinter phishing-domain.tld, eigener Bestand prüfen»	
08:15:38	PLAN	6 Abfragen an 4 Dienste vorgeschlagen · 3 Kontingenteinheiten	
08:15:52	FREIGABE	durch M.B. bestätigt — keine Abfrage nach aussen sichtbar	
08:16:44	ABFRAGE	shodan.host(185.x.x.x) → 3 Dienste, 1 Zertifikat	[a3f1...9c2e]
08:16:45	QUELLE	3 Entitäten übernommen, Herkunft gesetzt	
08:17:02	ABFRAGE	misp.search(185.x.x.x) → 2 Treffer aus Fall 2026-0311	[b7c2...41ad]
08:17:09	ABFRAGE	abuseipdb.check(185.x.x.x) → 14 Meldungen	[c4d8...77b1]
08:17:15	ABFRAGE	crt.sh(phishing-domain.tld) → 4 Subdomains	[d9e0...2f3c]
08:17:22	NEGATIV	urlhaus.lookup(185.x.x.x) → kein Treffer	[e1a5...8b6d]
08:17:48	SCHLUSS	Modell: Zertifikat-CN ähnelt Domain aus Fall 2026-0311 — UNBELEGT	
08:18:03	VORSCHLAG	Registrant über DomainTools prüfen? → wartet auf Freigabe	

Zeile 08:17:22 ist ein Negativbefund, Zeile 08:17:48 eine Schlussfolgerung des Modells — beide erscheinen zwingend im Protokoll.

Auszug aus einer Arbeitsspur. Jede Zeile mit Prüfsumme verweist auf den zugehörigen Eintrag im Prüfprotokoll.

Vier Eigenschaften, auf die es ankommt

Vollständigkeit — auch das, was nichts ergab

Wenn das System eine Quelle abfragt und keinen Treffer erhält, erscheint das als **Negativbefund** im Protokoll. Das ist kein technisches Detail: Der Umstand, dass eine Adresse in einer bestimmten Datenbank *nicht* verzeichnet war, kann entlastend sein und ist gegebenenfalls offenzulegen. Ein Protokoll, das nur Treffer festhält, wäre ein einseitiges Protokoll.

Trennung von Quelle und Schluss

Jede Zeile ist entweder eine **Quellenaussage** — das hat ein Dienst geliefert — oder eine **Schlussfolgerung des Modells**. Beides wird unterschiedlich gekennzeichnet, im Protokoll wie in der Darstellung. Damit lässt sich später zweifelsfrei auseinanderhalten, was erhoben und was gefolgert wurde. Das ist die wichtigste einzelne Absicherung gegen den Vorwurf, eine Maschine habe Tatsachen erfunden.

Freigaben sind Teil des Protokolls

Jede Freigabe durch die Ermittlerin steht mit Zeitpunkt und Person im Protokoll. Damit ist belegbar, dass keine Abfrage ohne menschlichen Entscheid ausgelöst wurde — und wer diesen Entscheid getroffen hat.

Beide Spuren hängen an derselben Kette

Jeder Eintrag beider Spuren trägt die Prüfsumme seines Vorgängers. Wird nachträglich an einer Spur etwas geändert oder entfernt — auch an der Arbeitsspur — bricht die Kette und die Prüfung zeigt es an. Man kann also nicht das Ergebnis behalten und den Weg dorthin stillschweigend bereinigen.

Was das praktisch bedeutet

Am Ende einer Ermittlung lassen sich beide Spuren als Dokument exportieren. Die Ermittlungsspur geht in die Akte. Die Arbeitsspur wird beigelegt oder auf Verlangen herausgegeben. Wer die Auswertung überprüfen will, kann jeden Schritt nachvollziehen, ohne uns glauben zu müssen — und im Streitfall lässt sich die Abfolge technisch verifizieren.

6 Szenario 1 — Phishing gegen ein Berner KMU

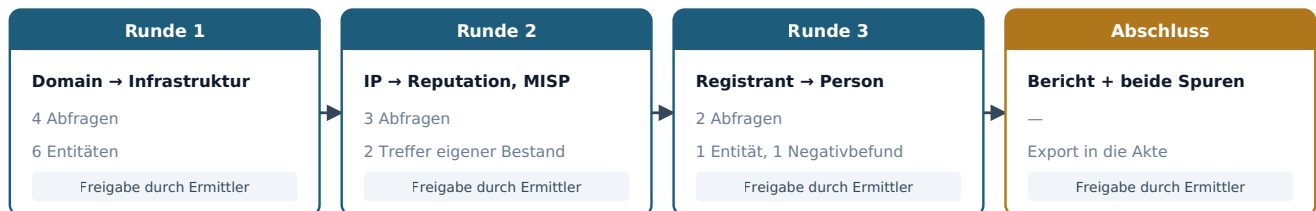
KERNAUSSAGE

Vom Domainnamen zur Verbindung mit einem laufenden Verfahren in rund zwölf Minuten und drei Runden — mit drei Freigaben und einem dokumentierten Negativbefund.

Ausgangslage

Eine Berner Treuhandfirma zeigt an, dass Mitarbeitende auf einer nachgebauten Login-Seite Zugangsdaten eingegeben haben. Bekannt ist zu Beginn ausschliesslich der Domainname aus der Phishing-Mail. Kein Absender, keine IP, kein Hinweis auf Täterschaft.

ABLAUF IN RUNDEN — VOR JEDER RUNDE STEHT EINE FREIGABE



Gesamtdauer im Beispiel: rund 12 Minuten, davon etwa 3 Minuten Wartezeit auf externe Dienste.

Die Ermittlung läuft in Runden. Vor jeder Runde entscheidet die Ermittlerin, ob und wie weit es weitergeht.

Runde 1 — Infrastruktur

1 Fall eröffnen

Aktenzeichen KRIPO-2026-0417, ermittelnde Person, Rechtsgrundlage, Aufbewahrungsklasse. Ohne diesen Schritt lässt sich kein Werkzeug aufrufen.

2 Auftrag

«Infrastruktur hinter dieser Domain, und prüfe unseren eigenen Bestand.»

3 Vorschau und Freigabe

Vier Abfragen an drei Dienste, keine davon für die Gegenseite sichtbar. Freigabe erteilt.

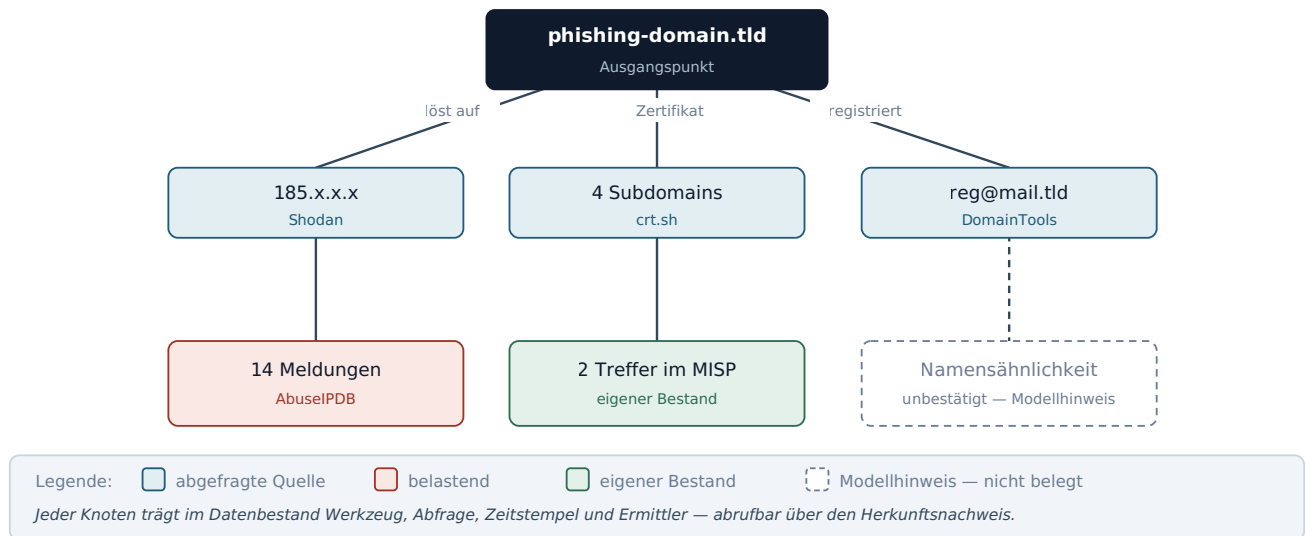
4 Ergebnis

IP-Adresse, vier Subdomains aus dem Zertifikatsprotokoll, Registrantenadresse. Sechs neue Entitäten.

Runde 2 — Reputation und eigener Bestand

Das System schlägt vor, die gefundene IP gegen Reputationsdienste und gegen unser MISP zu prüfen. Nach Freigabe: 14 Missbrauchsmeldungen — und **zwei Treffer im eigenen Bestand**. Dieselbe IP war in einem anderen Berner Verfahren bereits erfasst worden.

Eine weitere Abfrage bleibt ohne Treffer. Sie erscheint dennoch als Negativbefund im Protokoll.



Ergebnis nach Runde 2. Der gestrichelte Knoten ist eine Schlussfolgerung des Modells und ausdrücklich kein Beleg.

Runde 3 und Abschluss

Die Registrantenadresse wird geprüft. Das Modell weist zusätzlich auf eine Namensähnlichkeit zu einem Zertifikat aus dem anderen Verfahren hin — als Hinweis gekennzeichnet, nicht als Beleg. Die Ermittlerin entscheidet, diesen Punkt manuell in Maltego weiterzuverfolgen.

Der eigentliche Ertrag

Der wertvollste Fund ist nicht die Infrastruktur, sondern die Verbindung zum laufenden Verfahren. Genau dieser Abgleich geht im heutigen Ablauf am häufigsten unter, weil er von Hand erfolgt und unter Zeitdruck ausgelassen wird. Hier lief er bei jedem einzelnen Indikator automatisch mit.

Was am Ende in der Akte liegt

Ermittlungsspur: Graph mit neun Entitäten, Berichtsentwurf mit Herkunftsangabe je Aussage.

Arbeitsspur: 11 Abfragen, 3 Freigaben, 1 Negativbefund, 1 markierte Schlussfolgerung des Modells — mit Zeitstempeln und durchgehender Prüfkette.

7 Szenario 2 — Ransomware und Kryptospur

KERNAUSSAGE

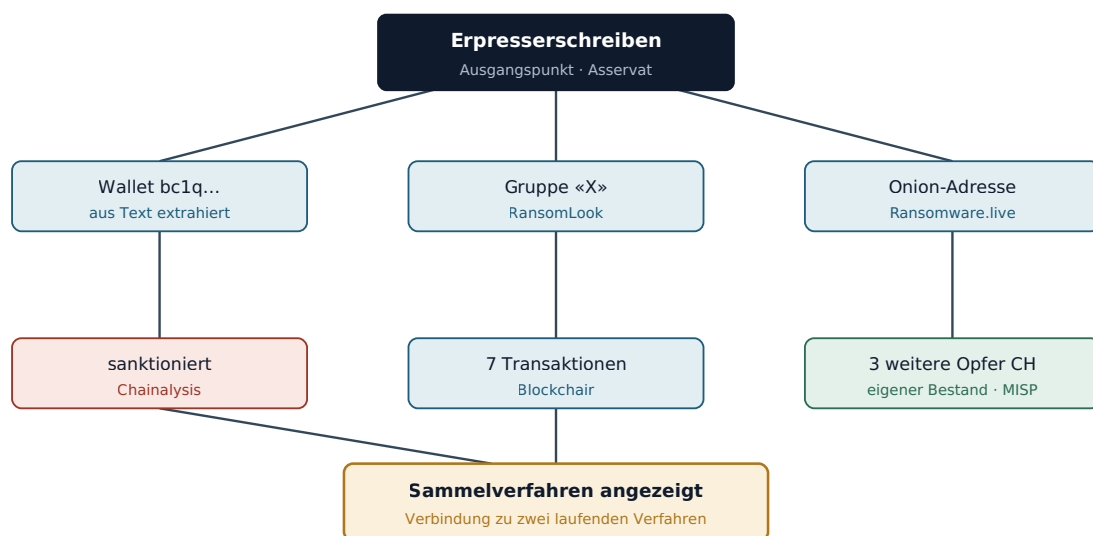
Ein anderer Werkzeugmix, dasselbe Verfahren. Vom Erpresserschreiben über die Wallet-Adresse zur Sanktionsprüfung — und zu drei weiteren Schweizer Geschädigten im eigenen Bestand.

Ausgangslage

Ein Gemeindeverwaltungs-Netz ist verschlüsselt. Vorliegend ist das Erpresserschreiben mit einer Bitcoin-Adresse und dem Namen einer Tätergruppe. Die Fragen: Wer steckt dahinter, ist die Adresse sanktioniert, und sind weitere Stellen in der Schweiz betroffen?

Ablauf

- 1 **Asservat erfassen**
Das Erpresserschreiben wird als Asservat mit Prüfsumme abgelegt. Die Wallet-Adresse und der Gruppenname werden daraus übernommen — mit Herkunftsangabe auf das Asservat.
- 2 **Sanktionsprüfung — zuerst**
Die Wallet-Adresse wird gegen die Sanktionsliste geprüft. Das steht bewusst am Anfang: Ein Treffer ändert die rechtliche Lage und die Meldepflichten sofort.
- 3 **Gruppe zuordnen**
Der Gruppenname wird gegen die offenen Leak-Site-Verzeichnisse geprüft. Ergebnis: bekannte Gruppe, aktive Leak-Seite, veröffentlichte Opferliste.
- 4 **Eigener Bestand**
Abgleich der Opferliste und der Adresse gegen unser MISP. **Drei weitere Schweizer Geschädigte**, davon zwei ohne bisherige Anzeige.
- 5 **Geldfluss**
Öffentliche Blockchain-Daten zeigen sieben ausgehende Transaktionen. Die weitergehende Zuordnung bleibt den dafür vorgesehenen Werkzeugen und der Rechtshilfe vorbehalten.



Der entscheidende Fund ist rechts unten: drei weitere Schweizer Geschädigte aus unserem eigenen Bestand — im heutigen Ablauf leicht zu übersehen.

Ergebnis des Szenarios. Die Sanktionsprüfung steht bewusst früh, weil ein Treffer die Meldepflichten unmittelbar verändert.

Was dieses Szenario zusätzlich zeigt

Der Werkzeugmix ist ein völlig anderer als in Szenario 1 — Krypto, Darknet-Verzeichnisse, Sanktionslisten statt Netzinfrastruktur. Das Verfahren, die Freigaben und die beiden Protokollspuren sind identisch. Genau darin liegt der Nutzen: ein Ablauf für sehr unterschiedliche Deliktsfelder.

Der Fund führt über den Einzelfall hinaus. Zwei bisher nicht angezeigte Geschädigte in der Schweiz sind ein Ergebnis, das ein einzelner Fall normalerweise nicht hervorbringt — und ein möglicher Anlass für ein Sammelverfahren.

Grenzen, die im Bericht stehen müssen

Die Sanktionsprüfung liefert eine Ja-Nein-Aussage zu Listentreffern, keine Zuordnung zu einer Person. Die offenen Blockchain-Daten zeigen Bewegungen, nicht Eigentümerschaft. Beides wird im Berichtsentwurf ausdrücklich so benannt, damit aus einem Ermittlungsansatz im weiteren Verlauf keine Tatsachenbehauptung wird.

8 Welche Quellen angebunden werden

KERNAUSSAGE

Rund 33 Quellen. Bei VirusTotal und urlscan sind zwei Punkte vor der Anbindung zu klären.

Rund 33 Quellen, gruppiert nach Ermittlungsphase. Der überwiegende Teil ist kostenlos oder bereits durch bestehende Verträge abgedeckt.

ABGEDECKTE QUELLEN — GRUPPIERT NACH ERMITTLUNGSPHASE

Infrastruktur & Netz

crt.sh

GreyNoise

AbuseIPDB

Shodan

urlscan.io

DomainTools

Malware & CTI

MISP

MalwareBazaar

URLhaus

ThreatFox

NVD / KEV / EPSS

VirusTotal

Kryptowährungen

Chainalysis Sanctions

Blockchair

Blockstream

Etherscan

Tatum

Personen & Identität

Sherlock / Maigret

holehe

PhoneInfoga

HIBP

Epieos

Sanktionen & Register

OpenSanctions

GLEIF

Zefix (CH)

OpenCorporates

Darknet & Leaks

RansomLook

Ransomware.live

Geo & Verkehr

Overpass / OSM

GeoNames

OpenSky

Mapillary

SunCalc

Google Geocoding

Beweissicherung

Wayback Machine

exiftool

☐ kostenlos

☐ bereits lizenziert / einmalig

☐ selbst gehostet

☐ Beschaffung nötig

Quellenlandschaft nach Ermittlungsphase. Farbe zeigt den Beschaffungsstatus.

Bestehende Bausteine, die wir nicht neu bauen

Für einen Teil der Quellen existieren bereits fertige, gepflegte Anbindungen — teils von den Herstellern selbst. Wir übernehmen diese, statt sie nachzubauen: unter anderem für MISP (vom MISP-Projekt selbst), für TheHive, für Cortex, für OpenSanctions sowie für die Darstellung in Mermaid und draw.io. Das reduziert den Eigenbau erheblich und verringert den Pflegeaufwand.

Punkte, die vor der Anbindung zu klären sind

VirusTotal — vertraglicher Konflikt

Die kostenlose Schnittstelle von VirusTotal ist laut deren Nutzungsbedingungen nicht für Abläufe zugelassen, die lediglich abfragen ohne neue Dateien beizutragen — und nicht für kommerzielle beziehungsweise dienstliche Abläufe. Unser Einsatzzweck fällt genau darunter. **Das Modul wird deshalb standardmässig deaktiviert ausgeliefert** und erst nach Abschluss einer entsprechenden Vereinbarung freigeschaltet. Die Preise werden individuell offeriert.

urlscan.io — Signalwirkung

Scans auf urlscan.io sind standardmässig öffentlich einsehbar. Eine Abfrage zur Infrastruktur einer Zielperson wäre damit für Dritte sichtbar. Im System ist **«nicht öffentlich» als Grundeinstellung fest hinterlegt**; eine öffentliche Abfrage erfordert eine ausdrückliche Übersteuerung im Einzelfall.

Schlüsselweitergabe im Team — geprüft

Nicht jeder Anbieter erlaubt es, einen Zugangsschlüssel im Team zu teilen. Geprüft und bestätigt: **Shodan erlaubt es ausdrücklich** («nach Nutzung abgerechnet, nicht nach Personen»), und **das NIST empfiehlt für grössere Stellen sogar ausdrücklich einen einzigen Schlüssel** hinter einem vorgelagerten Server — also genau unser Aufbau. Für HIBP, DomainTools, urlscan und Chainalysis sind die Vertragsbedingungen vor der Inbetriebnahme noch zu prüfen.

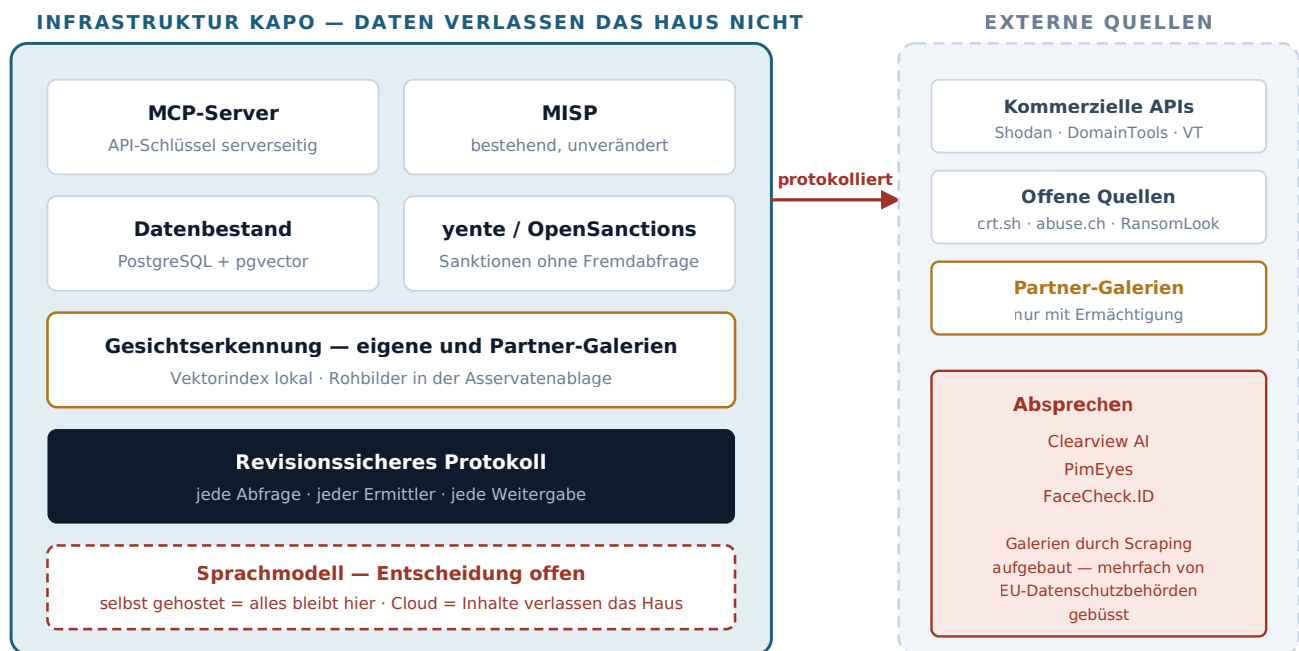
Unabhängig davon löst der gewählte Aufbau das Problem weitgehend: Die Anbieterschlüssel liegen ausschliesslich auf dem Server. Die Ermittelnden melden sich einzeln und persönlich am Server an. Damit bleibt jede Abfrage einer Person zurechenbar, obwohl nach aussen ein gemeinsamer Schlüssel verwendet wird.

9 Datenfluss und Vertrauensgrenzen

KERNAUSSAGE

Alles bleibt im Haus — mit einer Ausnahme, über die noch zu entscheiden ist: das Sprachmodell.

Die wichtigste Frage bei einem solchen System lautet nicht, was es kann, sondern welche Daten das Haus verlassen. Diese Übersicht beantwortet sie.



Vertrauensgrenzen. Jede Linie, die den linken Bereich verlässt, ist eine Bekanntgabe und wird protokolliert.

Was im Haus bleibt

Der Datenbestand, das Protokoll, MISP, die Sanktionsprüfung und der Vektorindex der Gesichtserkennung laufen vollständig auf unserer eigenen Infrastruktur. Bei der Sanktionsprüfung ist das ein bewusster Entscheid: OpenSanctions liesse sich auch als Fremddienst abfragen — dann würden aber die Namen unserer Zielpersonen an einen Dritten übermittelt. Die selbst betriebene Variante ist quelloffen, kostenlos und vermeidet das.

Was hinausgeht — und was das bedeutet

Jede Abfrage an eine externe Quelle ist eine Bekanntgabe: Wir teilen einem Dritten mit, dass wir uns für eine bestimmte Domain, IP-Adresse oder Person interessieren. Das ist bei Ermittlungsarbeit unvermeidbar, muss aber sichtbar und begrenzt sein. Deshalb: Positivliste erlaubter Gegenstellen, Protokollierung jeder Abfrage nach aussen, Kontingente je Fall, und die Möglichkeit, das System vollständig offline zu betreiben — der Datenbestand und die Darstellung funktionieren auch dann.

Der eine offene Punkt: das Sprachmodell

Alles Bisherige bleibt auf unserer Infrastruktur. Beim Sprachmodell selbst hängt das von einem Entscheid ab, den wir noch treffen müssen.

Selbst betrieben: Falldaten verlassen das Haus nie. Höherer Aufwand für Hardware und Betrieb, etwas geringere Modellqualität.

Cloud-Anbieter: Bessere Modellqualität, kein Betriebsaufwand — aber Inhalte, über die das Modell nachdenkt, also Namen, Adressen und Indikatoren, werden an einen Anbieter im Ausland übermittelt.

Der Aufbau sieht die selbst betriebene Variante als gleichwertig unterstützte Möglichkeit vor. Der Entscheid ist vor Baubeginn zu treffen, weil er sich später nur mit erheblichem Aufwand ändern lässt. Er ist mit dem Datenschutz und der Staatsanwaltschaft abzustimmen.

10 Modul Gesichtserkennung

KERNAUSSAGE

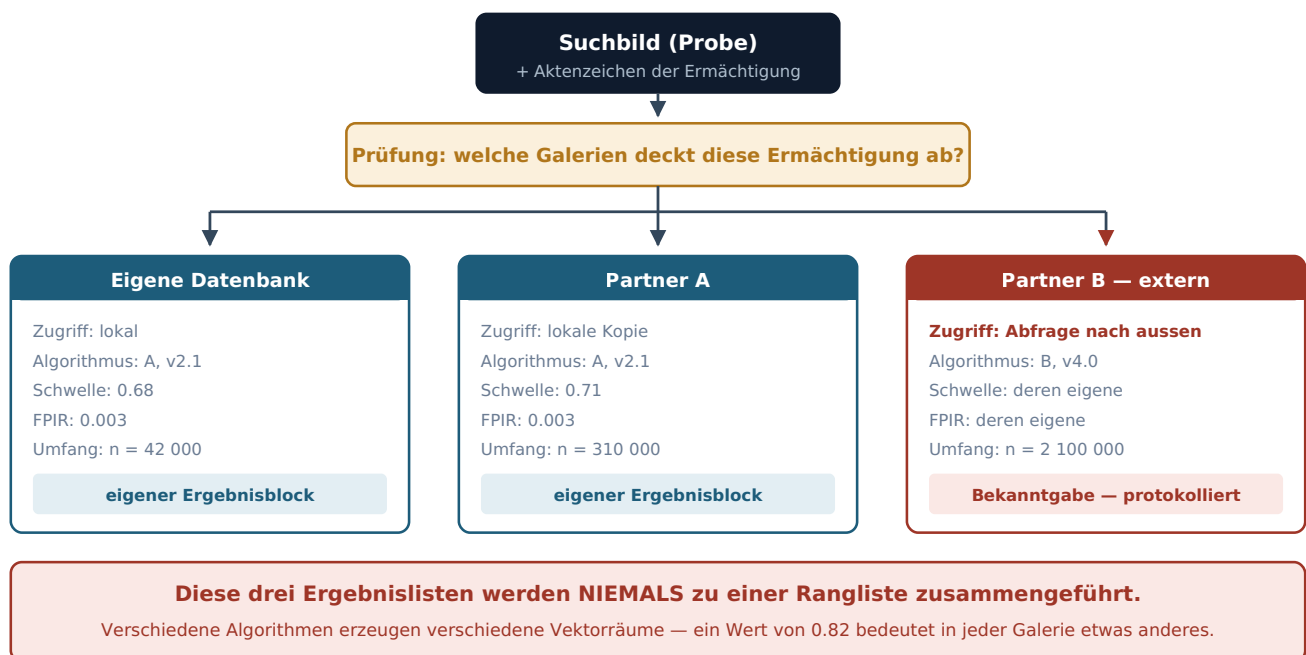
Getrennt gebaut, standardmässig aus. Jede Galerie trägt ihre eigene Rechtsgrundlage — Ergebnisse werden nie zu einer Rangliste zusammengeführt.

Dieses Modul wird getrennt gebaut, ist standardmässig ausgeschaltet und wird nur für Fälle freigeschaltet, in denen eine staatsanwaltschaftliche Ermächtigung vorliegt.

Zwei Fragen, die auseinanderzuhalten sind

Die staatsanwaltschaftliche Ermächtigung beantwortet die Frage, **ob wir die Massnahme durchführen dürfen**. Sie beantwortet nicht die davon getrennte Frage, **ob die Vergleichsdatenbank rechtmässig aufgebaut wurde**.

Bei unserer eigenen Datenbank und bei den Partnerbeständen, für die entsprechende Vereinbarungen und Ermächtigungen vorliegen, sind beide Fragen beantwortet. Bei kommerziellen Anbietern, die ihre Bestände durch das massenhafte Abgreifen von Bildern aus dem Internet aufgebaut haben, ist die zweite Frage negativ beantwortet — mehrere europäische Datenschutzbehörden haben solche Anbieter deswegen gebüsst. Eine Ermächtigung für die Massnahme heilt diesen Mangel nicht; sie würde ihn in unsere Akte hineintragen. Solche Dienste sind daher technisch ausgeschlossen: Eine Galerie muss ausdrücklich registriert sein, und die Registrierung verlangt die Angabe der Rechtsgrundlage.



Galeriemodell. Jede Galerie trägt ihre eigene Rechtsgrundlage, ihren eigenen Algorithmus und ihre eigene Schwelle.

Weshalb Ergebnisse nicht zusammengeführt werden

Das ist der fachlich heikelste Punkt des Moduls, weil ein Fehler hier zu Ergebnissen führt, die plausibel aussehen und falsch sind.

Verschiedene Algorithmen sind nicht vergleichbar. Jedes Erkennungsverfahren bildet Gesichter in einen eigenen mathematischen Raum ab. Ein Ähnlichkeitswert von 0.82 bedeutet bei Verfahren A etwas anderes als bei Verfahren B. Werte aus verschiedenen Galerien in eine gemeinsame Rangliste zu sortieren, erzeugt eine Scheingenauigkeit.

Schwellenwerte sind nicht übertragbar. Das amerikanische NIST hat dokumentiert, dass die zu erwartende Zahl von Fehltreffern davon abhängt, wie häufig eine Personengruppe in der jeweiligen Galerie vertreten ist, wie hoch die Fehlerraten innerhalb dieser Gruppe sind und wie hoch sie gegenüber anderen Gruppen sind — Letzteres ist ausdrücklich nicht vernachlässigbar. Eine Schwelle, die auf unserem eigenen Bestand kalibriert wurde, verhält sich auf einem Partnerbestand anders.

Die Galeriegrösse verändert die Rechnung. Ein Fehltreffer tritt bereits dann auf, wenn auch nur ein einziger von n Vergleichen die Schwelle überschreitet. Eine Suche in 42 000 Datensätzen und eine Suche in 2 100 000 Datensätzen sind bei gleicher Schwelle nicht dieselbe Operation.

Wie ein Ergebnis aussieht

Das Modul liefert **nie eine Aussage «Treffer»**. Es liefert je Galerie einen eigenen Block mit Ähnlichkeitswert, angewandter Schwelle, Fehlerrate bei dieser Schwelle, Algorithmus samt Version und Galeriegrösse — verbunden mit dem ausdrücklichen Hinweis, dass es sich um einen Ermittlungsansatz handelt, der fachlich zu bestätigen ist.

Das entspricht der Systematik des NIST selbst: Dessen Prüfprogramm unterscheidet ein Verfahren für automatisierte Entscheide von einem *Investigation*-Verfahren für die Strafverfolgung, dessen Ergebnisse ausdrücklich zur weiteren menschlichen Prüfung bestimmt sind — zum Bestätigen oder Verwerfen der zurückgegebenen Kandidaten. Wir bauen konsequent Letzteres.

Vor dem Bau zu klären: Lizenz und Nachweisbarkeit

Die verbreiteten quelloffenen Erkennungsmodelle sind für unseren Einsatz nicht ohne Weiteres verwendbar. Beim führenden Projekt steht der Programmcode zwar unter einer freien Lizenz, **die vortrainierten Modelle sind jedoch ausdrücklich auf nicht-kommerzielle Forschungszwecke beschränkt**. Ein polizeilicher Wirkbetrieb fällt nicht darunter. Bei zwei weiteren verbreiteten Werkzeugen ist die Frage bis heute unbeantwortet offen.

Empfehlung: Beschaffung eines kommerziell lizenzierten Erkennungsverfahrens, das am NIST-Prüfprogramm teilnimmt. Das löst drei Probleme auf einmal: eindeutige Lizenz für den Behördeneinsatz, veröffentlichte und damit im Verfahren zitierbare Fehlerraten einschliesslich der Unterschiede zwischen Personengruppen, sowie ein greifbarer Anbieter. Das System wird so gebaut, dass sich das Verfahren austauschen lässt.

Was wir von der Gruppe brauchen

Das Modul lässt sich nicht bauen, bevor jede einzelne Galerie erfasst ist: verantwortliche Stelle, Rechtsgrundlage, welche Ermächtigungen sie abdeckt, Zugriff lokal oder als Abfrage nach aussen, verwendetes Verfahren, Schwelle und Fehlerrate, Umfang, Aufbewahrungsfrist. Diese Angaben kann nur die Gruppe liefern.

11 Absicherung und Gerichtsfestigkeit

KERNAUSSAGE

Die Absicherungen sind Bauvorschrift, nicht Nachtrag. Verkettete Protokollierung, Herkunft an jedem Datenpunkt, Freigabe vor Ausführung.

Die Absicherungen sind nicht als nachträgliche Ergänzung gedacht, sondern als Bauvorschrift. Sie lassen sich im Betrieb nicht abschalten.

PROTOKOLLKETTE — JEDER EINTRAG TRÄGT DEN HASH SEINES VORGÄNGERS



Ein nachträglich geänderter oder gelöschter Eintrag bricht die Kette und wird bei der Prüfung sichtbar.

Verkettete Protokollierung. Jeder Eintrag enthält die Prüfsumme des vorhergehenden.

Die verkettete Protokollierung

Jeder Vorgang erzeugt einen Protokolleintrag mit Zeitpunkt, Aktenzeichen, Person, Werkzeug, Abfrageinhalt, Ergebnisumfang, Kontingentverbrauch und Ausgang. Jeder Eintrag trägt zusätzlich die Prüfsumme seines Vorgängers. Wird ein Eintrag nachträglich verändert oder entfernt, bricht die Kette an dieser Stelle, und die Prüfung zeigt es an. Die Protokolle sind ausschliesslich anfügbar; ein Bearbeiten ist nicht vorgesehen.

Zugleich gilt: Die Werte selbst — Namen, Adressen, Telefonnummern — werden im Protokoll standardmässig unkenntlich gemacht oder als Prüfsumme abgelegt. Das Protokoll soll belegen, was getan wurde, ohne selbst zu einer zweiten, unkontrollierten Kopie der Falldaten zu werden.

Die weiteren Absicherungen im Überblick

Absicherung	Was sie bewirkt
Fallbindung	Ohne eröffneten Fall ist kein einziges Werkzeug aufrufbar. Jede Abfrage ist damit zwingend einem Verfahren und einer Person zugeordnet.
Freigabe vor Ausführung	Keine Abfrage nach aussen ohne bestätigte Vorschau. Das System kann Vorschlag und Ausführung nicht selbstständig verketten.
Herkunft an jedem Datenpunkt	Kein Knoten und keine Verbindung ohne Herkunftsnachweis. Schlussfolgerungen des Modells sind gesondert gekennzeichnet und in jeder Darstellung optisch abgesetzt.
Positivliste nach aussen	Nur ausdrücklich freigegebene Gegenstellen sind erreichbar. Jeder Versuch darüber hinaus wird abgewiesen und protokolliert.
Kontingentgrenzen	Verbrauch je Fall und je Tag begrenzt. Verhindert, dass ein Kontingent mitten in einem Verfahren unbemerkt aufgebraucht ist.
Behandlung fremder Inhalte	Alles, was von aussen kommt — Meldungen, Webseiten, Leak-Inhalte — wird als potenziell manipuliert behandelt und dem Modell ausdrücklich als Daten, nicht als Anweisung übergeben.
Reproduzierbarkeit	Feste Programmstände, gleiche Eingaben ergeben gleiche Ausgaben. Eine Auswertung muss ein Jahr später nachvollziehbar wiederholbar sein.
Kein Rückkanal	Keine Nutzungsstatistik, keine Fehlerberichte, keine Aktualisierungsabfragen nach aussen. Wird durch eine Prüfung im Bauprozess kontrolliert.

Zur Behandlung fremder Inhalte — ein Punkt, der leicht unterschätzt wird

Wenn ein Sprachmodell Inhalte verarbeitet, die eine Täterschaft selbst erstellt hat — etwa den Text einer Leak-Seite oder einen manipulierten Registereintrag — kann darin gezielt Text eingebettet sein, der das Modell zu einem bestimmten Verhalten verleiten soll. Das ist keine theoretische Sorge, sondern ein bekanntes Angriffsmuster. Deshalb wird jeder von aussen bezogene Inhalt gekennzeichnet an das Modell übergeben, und das System ist so gebaut, dass Anweisungen aus solchen Inhalten keine Werkzeuge auslösen können.

12 Kosten

KERNAUSSAGE

Der Kern kostet rund 5 Franken pro Monat. Der eigentliche Aufwand liegt in der Entwicklungszeit, nicht in Lizenzen.

Der überwiegende Teil der Quellen ist kostenlos oder bereits durch bestehende Verträge abgedeckt. Die wiederkehrenden Kosten des Kernsystems liegen im einstelligen Frankenbereich pro Monat.

KOSTENSTRUKTUR NACH ANZAHL QUELLEN

Kostenlos / offene Quellen	 26 Quellen — 0.—
Einmalig (Shodan)	 einmalig ca. 5.— bis 49.—
Laufend gering (HIBP)	 ca. 4.40 / Monat
Bereits lizenziert	 DomainTools, Chainalysis
Beschaffung offen	 VirusTotal, Epieos, Gesichts-SDK

Wiederkehrende Kosten des Kernsystems: rund 5 Franken pro Monat.

Kostenstruktur nach Anzahl angebundener Quellen. Stand der Erhebung: 11. August 2026.

Im Einzelnen

Position	Kosten	Bemerkung
26 offene Quellen	0.—	crt.sh, abuse.ch, GreyNoise, AbuseIPDB, NVD, RansomLook, OpenSky, Overpass und weitere
Shodan	einmalig ca. 5.— bis 49.—	Einmalzahlung, keine Abonnementskosten. Der Anbieter führt regelmässig eine Aktion zu 5.— durch — abwarten lohnt sich.
HIBP	ca. 4.40 / Monat	Einstiegsstufe. Die Passwortprüfung ist separat und kostenlos nutzbar.
OpenSanctions	0.—	Selbst betrieben, quelloffen. Für gemeinnützige und behördliche Zwecke werden zudem kostenlose Zugänge vergeben — eine Anfrage lohnt sich.
DomainTools	bestehend	Vertrag vorhanden, keine Zusatzkosten
Chainalysis	0.— für Sanktionsprüfung	Die Sanktionsabfrage ist kostenlos. Die Ermittlungswerkzeuge sind separat zu beschaffen.

Google Geocoding	voraussichtlich 0.—	10 000 Abfragen pro Monat kostenlos; darüber 5.— je 1000. Für unser Volumen ausreichend. Achtung: das frühere allgemeine Guthaben wurde im März 2025 abgeschafft.
Beweissicherung	ca. 130.— / Jahr	Empfehlung für gerichtsfeste Web-Sicherung mit Prüfsummen. Separates Werkzeug, keine Schnittstelle.
VirusTotal	offen	Individuelles Angebot nötig, siehe Kapitel 10 (S. 16). Deutlich höhere Größenordnung.
Gesichtserkennung	offen	Lizenz zu klären, siehe Kapitel 10 (S. 16). Empfehlung: kommerziell lizenziertes, geprüftes Verfahren.
Betrieb	intern	Server für Datenbestand und Sanktionsprüfung. Richtwert für Letztere: 8 GB Arbeitsspeicher, 60 GB Speicher.

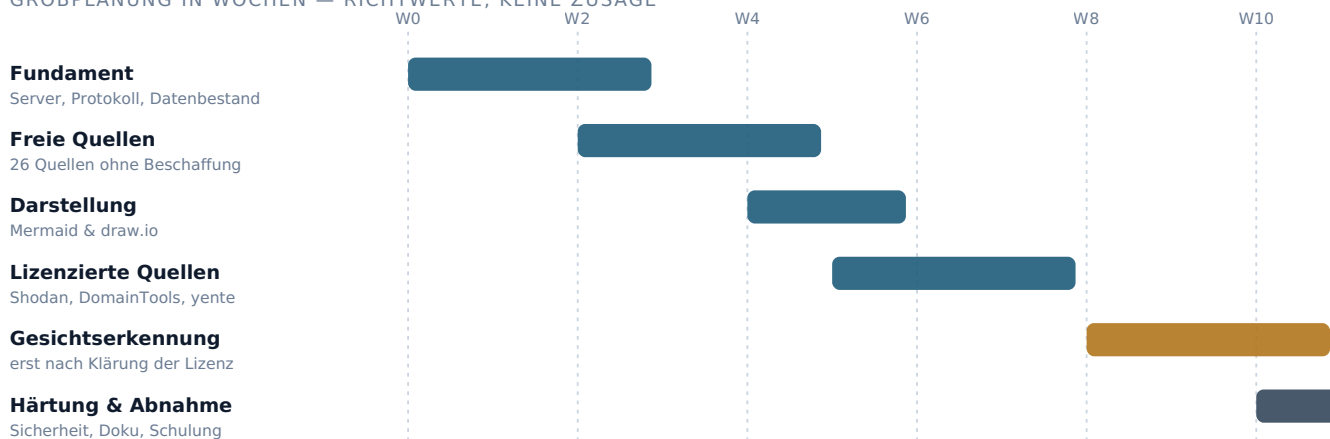
Alle Preisangaben Stand 11. August 2026, erhoben aus den Angaben der Anbieter. Preise und Nutzungsgrenzen ändern sich häufig und sind vor einer Beschaffung erneut zu prüfen. Der wesentliche Aufwand dieses Vorhabens liegt nicht bei den Lizenzen, sondern in der Entwicklungs- und Betriebszeit.

13 Zeitplan und offene Entscheide

KERNAUSSAGE

Mit den Etappen 1 bis 3 kann sofort begonnen werden. Acht Entscheide sind zu treffen, davon drei vor Baubeginn.

GROBPLANUNG IN WOCHEN — RICHTWERTE, KEINE ZUSAGE



Grobplanung. Die Gesichtserkennung ist bewusst spät angesetzt, weil sie von einem offenen Entscheid abhängt.

Vorgehen

Gebaut wird in Etappen, jede mit einem überprüfbaren Ergebnis. Nach der ersten Etappe steht ein lauffähiges System mit dem Datenbestand und der Protokollierung — ohne jede externe Abfrage. Erst danach kommen die Quellen dazu, beginnend mit denen, die keine Beschaffung erfordern. So entsteht früh etwas Vorzeigbares, und die Absicherungen sind vor der ersten echten Abfrage fertig, nicht danach.

Was wir von euch brauchen

1. Sprachmodell: selbst betrieben oder Cloud?

Der einzige Punkt, an dem Falldaten das Haus verlassen könnten. Später nur mit erheblichem Aufwand änderbar. **Entscheid: Gruppenleitung mit Datenschutz und Staatsanwaltschaft**

2. Verzeichnis sämtlicher Galerien für die Gesichtserkennung

Je Galerie: verantwortliche Stelle, Rechtsgrundlage, abgedeckte Ermächtigungen, Zugriffsart, Verfahren, Schwelle, Fehlerrate, Umfang, Aufbewahrungsfrist. Ohne diese Angaben ist das Modul nicht baubar.

Zuliefernd: Ermittlungsgruppe und Partnerstellen

3. VirusTotal — Vereinbarung abschliessen oder verzichten?

Ohne Vereinbarung bleibt das Modul deaktiviert. Ein Verzicht ist vertretbar, weil abuse.ch und unser eigenes MISP einen erheblichen Teil abdecken. **Entscheid: Gruppenleitung, Beschaffung**

4. Erkennungsverfahren beschaffen?

Empfehlung ist ein kommerziell lizenziertes, am NIST-Programm geprüfetes Verfahren — wegen der Lizenzlage und wegen der im Verfahren zitierbaren Fehlerraten. **Entscheid: Gruppenleitung, Beschaffung, Rechtsdienst**

5. Welches Datenschutzregime gilt?

Kantonales Polizeirecht, Schengen-Datenschutzgesetz oder revidiertes Datenschutzgesetz des Bundes — davon hängen Folgenabschätzung und Aufbewahrungsfristen ab. **Zu klären: Datenschutzbeauftragte, Rechtsdienst**

6. Ist eine Datenschutz-Folgenabschätzung nötig?

Bei biometrischer Verarbeitung naheliegend. Sollte vor dem Bau des Moduls geklärt sein, nicht danach. **Zu klären: Datenschutzbeauftragte**

7. Vertragsbedingungen zur Schlüsselweitergabe prüfen

Für HIBP, DomainTools, urlscan und Chainalysis noch offen. Shodan und NIST sind geklärt. **Zu prüfen: Beschaffung**

8. Aufbewahrungsfristen je Fallkategorie

Bestimmt, wann Daten und biometrische Vektoren automatisch gelöscht werden. Die Löswege werden gebaut und geprüft — die Fristen müssen aber gesetzt werden. **Zu setzen: Gruppenleitung mit Datenschutz**

Nächster Schritt

Besprechung dieses Konzepts in der Gruppe, anschliessend Klärung der Punkte 1, 5 und 6 mit Datenschutz und Staatsanwaltschaft. Die Punkte 2 und 4 werden erst vor Etappe 5 benötigt und blockieren den Beginn nicht. Mit den Etappen 1 bis 3 kann unmittelbar begonnen werden, da sie ausschliesslich kostenlose Quellen betreffen und keine Beschaffung voraussetzen.

A Anhang — Werkzeugverzeichnis

Vollständige Liste der vorgesehenen Quellen und Werkzeuge, gruppiert nach Einsatzgebiet. Preise und Nutzungsgrenzen Stand 11. August 2026 — vor einer Beschaffung erneut zu prüfen.

Werkzeug	Zweck	Kosten	Bemerkung
Bedrohungsinformationen (CTI)			
MISP	eigener Bestand, Indikatoren, Fallabgleich	selbst betrieben	vorhanden
MalwareBazaar	Schadsoftware-Proben nach Prüfsumme	kostenlos	Schlüssel gratis
URLhaus	bekannte Schadsoftware-URLs	kostenlos	Schlüssel gratis
ThreatFox	Indikatoren aus laufenden Kampagnen	kostenlos	Schlüssel gratis
VirusTotal	Datei- und URL-Analyse	offen	Vereinbarung nötig
Netz- und Infrastrukturanalyse			
Shodan	offene Dienste, Banner, Zertifikate	einmalig 5.- bis 49.-	Teilschlüssel erlaubt
crt.sh	Zertifikatsprotokoll, Subdomains	kostenlos	kein Schlüssel
urlscan.io	Analyse verdächtiger Webseiten	bestehend	nicht öffentlich erzwingen
DomainTools	Registrant, Historie, Risikobewertung	bestehend	Vertrag vorhanden
GreyNoise	Einordnung von Scan-Rauschen	kostenlos	Community-Stufe
AbuseIPDB	Missbrauchsmeldungen zu IP-Adressen	kostenlos	1000 Abfragen/Tag
Schwachstellen			
NIST NVD	Schwachstellendatenbank (CVE)	kostenlos	Schlüssel empfohlen
CISA KEV	aktiv ausgenutzte Schwachstellen	kostenlos	kein Schlüssel
EPSS	Wahrscheinlichkeit einer Ausnutzung	kostenlos	kein Schlüssel
Kryptowährungen			
Chainalysis Sanctions	Abgleich gegen Sanktionslisten	kostenlos	5000 Abfragen/5 Min.
Blockchair	Transaktionen mehrerer Ketten	kostenlos	Freistufe
Blockstream Explora	Bitcoin-Daten, selbst betreibbar	kostenlos	quelloffen
Etherscan	Ethereum-Transaktionen	kostenlos	Freistufe
Tatum	Zugang zu über 100 Ketten	kostenlos	Freistufe
Personen und Identität			
HIBP	Betroffenheit von Datenabflüssen	ca. 4.40/Monat	Passwortprüfung gratis
Sherlock / Maigret	Benutzernamen über Plattformen	kostenlos	quelloffen, selbst betrieben
holehe	Konten zu einer E-Mail-Adresse	kostenlos	quelloffen
PhoneInfoga	Auswertung von Rufnummern	kostenlos	quelloffen

Epieos	Rückwärtssuche E-Mail und Telefon	EUR 29.99/Monat	Schnittstelle nur Enterprise
Sanktionen, Register, Firmen			
OpenSanctions / yente	Sanktionen und politisch exponierte Personen	kostenlos	selbst betrieben
Zefix	Schweizer Handelsregister	kostenlos	Bedingungen prüfen
GLEIF	weltweite Rechtsträgerkennungen	kostenlos	kein Schlüssel
OpenCorporates	Firmendaten international	Freistufe	Bedingungen prüfen
Darknet und Leaks			
RansomLook	Erpressergruppen, Opferlisten, Wallets	kostenlos	quelloffen, CC BY 4.0
Ransomware.live	Leak-Seiten, Opferverzeichnis	kostenlos	quelloffen, EU-Hosting
Geo, Verkehr, Bildauswertung			
Overpass / Nominatim	Kartendaten und Ortsauflösung	kostenlos	OpenStreetMap
GeoNames	Ortsnamensverzeichnis	kostenlos	kein Schlüssel
Google Geocoding	Adresse zu Koordinaten	10 000/Monat gratis	danach 5.-/1000
OpenSky	Flugbewegungen (ADS-B)	kostenlos	Nutzungsbedingungen prüfen
Mapillary	Strassenansichten	kostenlos	Freistufe
SunCalc	Sonnenstand, Schattenwurf	kostenlos	quelloffen
exiftool	Metadaten aus Bilddateien	kostenlos	quelloffen, lokal
Beweissicherung und Darstellung			
Wayback Machine	Archivstände von Webseiten	kostenlos	kein Schlüssel
Mermaid	Beziehungsgraph als Text	kostenlos	quelloffen
draw.io	Graph zur Weiterbearbeitung	kostenlos	quelloffen
Hunchly	gerichts-feste Web-Sicherung	ca. 130.-/Jahr	Empfehlung, separat

Zusammenfassung

39 Werkzeuge in neun Gruppen. Davon **28 vollständig kostenlos**, **4 bereits durch bestehende Verträge abgedeckt oder einmalig zu zahlen**, **3 mit geringen laufenden Kosten** und **4 mit offener Beschaffung** (VirusTotal, Epieos, Hunchly, Erkennungsverfahren für das Gesichtsmodul).

Nicht enthalten — bewusst

Dienste, die ihre Vergleichsbestände durch das massenhafte Abgreifen von Bildern oder Personendaten aus dem Internet aufgebaut haben, sind nicht aufgeführt und technisch ausgeschlossen. Die Begründung steht in **Kapitel 10 (S. 16)**.